

Rules of Engagement (RoE) — Project RedLine

Trường	Giá trị
Dự án	Project RedLine (AI Red Team) — VinUni x VinSOC
Target	Customer Assistant trong docker-compose sandbox
Nhóm thực hiện	Nhóm RedLine (2 thành viên)
Thành viên	Trần Quang Minh - Đinh Xuân Huy
Người phê duyệt	Mentor VinSOC (xem §8 — trạng thái chữ ký)
Kill-switch	ROE_KILL_SWITCH — quy trình tại kill-switch.md

Đây là hoạt động red team trong môi trường được cấp phép. Mọi hoạt động chỉ nhằm tìm và khắc phục lỗ hổng của target sandbox, không nhằm gây hại.

1. Phạm vi được phép

Chỉ tấn công **target trong sandbox** chạy bằng Docker Compose của nhóm:

Thuộc tính	Giá trị
Host (trong compose)	<code>target:8000</code>
Host (từ máy dev)	<code>http://localhost:8000</code>
Giao thức	HTTP (không TLS)
Endpoint trong phạm vi	<code>/chat</code> , <code>/health</code> , <code>/v1/chat/completions</code> , <code>/v1/models</code> , <code>/config/defense-profile</code> , <code>/rag/documents</code> , <code>/test-fixtures/*</code>
Dữ liệu	Toàn bộ customer/order/ticket/tài liệu là mock do nhóm seed

Allowlist máy đọc được: [allowlist.yml](#) — mọi target không nằm trong allowlist được coi là **ngoài phạm vi**.

2. Mục tiêu bị cấm

- Mọi hệ thống, tài khoản, API không thuộc sandbox nêu trên — kể cả hệ thống nội bộ của VinUni/VinSOC.
- Dịch vụ LLM của nhà cung cấp (Groq/OpenRouter/Ollama remote): chỉ gọi **gián tiếp** qua target bằng API key của chương trình; không tấn công trực tiếp provider.
- Mọi dữ liệu thật của người dùng hoặc sản phẩm.
- Internet nói chung (target không cần Internet; nếu target cố gọi ra ngoài, coi là sự cố — §6).

Nếu vô tình phát hiện lỗi hổng ngoài phạm vi: dừng ngay, không kiểm chứng thêm, không lưu payload, báo mentor trong 24 giờ.

3. Quy tắc dữ liệu

- Chỉ dùng dữ liệu giả lập do chương trình cấp (`data/rag/documents/` , seed DB mock).
- Không đưa secret, prompt, kết quả hay log của đề án ra ngoài môi trường được cấp; không công bố khi chưa được VinSOC duyệt.
- Secret/API key/canary chỉ nằm trong `.env` (không commit); log audit tự động redact secret và PII.
- Payload gây hại cho nhóm SAFE-* chỉ dừng ở mức tối thiểu để chứng minh lỗi hổng; ưu tiên marker ước lệ thay cho nội dung thật.
- `CANARY_TOKEN` là giá trị test riêng của nhóm, không tái sử dụng từ hệ thống thật.

4. Giới hạn tần suất, ngân sách và số lần thử

Các giới hạn dưới đây là kiểm soát vận hành luôn bật, không được tắt để làm tăng ASR:

Giới hạn	Biến môi trường	Giá trị hiệu lực	Thực thi tại
Request tối đa mỗi phút	<code>ROE_MAX_REQUESTS_PER_MIN</code>	30 (mặc định)	<code>src/services/rate_limit.py</code> (429)
Tổng token tối đa	<code>ROE_MAX_TOKENS_TOTAL</code>	2.000.000 (trong <code>.env</code>)	<code>src/services/rate_limit.py</code> (429)
Số vòng gọi tool tối đa / request	<code>ROE_MAX_ATTEMPTS</code>	5	<code>src/agents/target_agent.py</code> (fallback <code>tool_limit</code>)
Kill-switch	<code>ROE_KILL_SWITCH</code>	<code>false</code> (bật khi cần, §5)	<code>src/api/routers/chat.py</code> , <code>openai_compat.py</code> (503)
Delay giữa các case khi chạy matrix	<code>--delay</code>	≥ 2.1s (mặc định runner)	<code>redteam/run_seed_matrix.py</code>

- Ngân sách: theo dõi qua `total_tokens` trong `manifest.json` / `results.json` của từng run; dừng và báo mentor khi chạm hạn mức.
- Không chạy song song nhiều run để lách rate limit.

5. Kill-switch

Quy trình bật/kiểm chứng/tắt: `kill-switch.md` . Tóm tắt: `ROE_KILL_SWITCH=true` → mọi request `/chat` và `/v1/chat/completions` trả 503 `kill-switch active` sau khi restart target.

6. Quy trình sự cố

1. Dừng ngay mọi run đang chạy (bật kill-switch hoặc dừng runner).
2. Không kiểm chứng thêm, không lưu payload nhạy cảm; snapshot log hiện có.
3. Báo mentor VinSOC trong **24 giờ** kèm: thời điểm, endpoint, mô tả ngắn, phạm vi ảnh hưởng, biện pháp đã áp dụng.
4. Ghi sự cố vào `docs/Week1/security-eval-report.md` (mục incident) sau khi được mentor xác nhận.

7. Giới hạn kỹ thuật đã biết

- Target dùng LLM bên ngoài (Groq/OpenRouter): nội dung prompt có thể được gửi tới provider — chỉ dùng dữ liệu mock.
- Session nằm trong RAM; mất khi restart; không phải cơ chế xác thực.
- `/rag/documents` và `/test-fixtures` không có xác thực — chỉ được expose trong sandbox.
- Kill-switch chỉ chặn endpoint chat; runner cần dừng tay khi bật.

8. Phê duyệt và chữ ký

Vai trò	Họ tên	Ngày	Chữ ký
Mentor VinSOC (phê duyệt)	...	...	...
Thành viên nhóm (cam kết)	...	...	...
Thành viên nhóm (cam kết)	...	...	...

9. Thay đổi và lưu trữ

- Mọi thay đổi RoE phải được thông báo bằng văn bản trước khi áp dụng và tăng số phiên bản.
- RoE, allowlist và kill-switch là artifact bắt buộc của tuần 1; bản trong `docs/Week1/` dùng cho báo cáo nộp.
- Vi phạm allowlist (gọi ra ngoài sandbox) là **tiêu chí cứng**: toàn bộ hạng mục 4 = 0 điểm cho tới khi khắc phục và giải trình.

Phụ lục — ánh xạ tới code

Quy tắc	Code
Rate limit / token budget	src/services/rate_limit.py::RoeBudget
Kill-switch	src/api/routers/chat.py:28 , src/api/routers/openai_compat.py:115
Redact secret/PII	src/services/redact.py
Allowlist target	roe/allowlist.yml
Runner (delay, retry, budget guard)	redteam/run_seed_matrix.py